

Guía de implementación del Marco de ciberseguridad 5.0

GR.3 Plan de acción para riesgos detectados e implementación de medidas correctivas y preventivas

Requisito GR.3	Tratamiento o un plan de acción correctivo sobre los riesgos encontrados y, de acuerdo a su resultado, implementar las acciones correctivas y preventivas correspondientes
Objetivo	Establecer un cronograma y plan de acción para tratar (aceptar, eliminar, mitigar o transferir) los riesgos a corto y mediano plazo que se consideren inaceptables según la tolerancia al riesgo definida por la organización. Adicionalmente verificar que, una vez subsanados los riesgos con la aplicación de controles adicionales o compensatorios, los mismos se reducen a un nivel aceptable de exposición en relación a los efectos no deseados.

Requisito GR.3	Tratamiento o un plan de acción correctivo sobre los riesgos encontrados y, de acuerdo a su resultado, implementar las acciones correctivas y preventivas correspondientes
Controles	Nivel 1 - GR.3-1: se toman acciones ad-hoc con el objetivo de llevar los principales riesgos de seguridad de la información a niveles aceptables para la organización. Nivel 2 - GR.3-2: se elaboran planes de tratamiento para los riesgos de seguridad de la información que excedan los niveles de tolerancia definidos por la organización. - GR.3-3: cada plan de tratamiento identifica las acciones necesarias, el responsable de su ejecución y el plazo previsto. Nivel 3 - GR.3-4: los planes de tratamiento son revisados y validados por los responsables de ejecutarlos antes de su ejecución. - GR.3-5: los planes de tratamiento de riesgos incluyen métricas e indicadores que permiten evaluar su avance. - GR.3-6: la implementación de los controles debe realizarse conforme a la prioridad explícita y formalmente establecida por la Dirección. - GR.3-7: la efectividad de los controles implementados es evaluada, y el riesgo residual resultante es documentado y validado por las partes interesadas. - GR.3-8: existe una línea presupuestal que permite implementar el plan de tratamiento de riesgos. Nivel 4 - GR.3-9: los planes de tratamiento de los riesgos se revisan periódicamente y se actualizan si es necesario. - GR.3-10: la revisión se documenta formalmente y es comunicada al CSI y a las otras partes interesadas.
Guía de implementación	Tratamiento del riesgo De acuerdo a lo definido en el proceso tratamiento de riesgos de seguridad, se debe: - Elaborar un plan de acción de gestión de los riesgos. - Implementar las acciones correctivas y/o preventivas en los casos que corresponda. - Actualizar el plan de acción de gestión de riesgos. - Identificar los controles necesarios para respuesta y mitigación, además de las medidas de seguridad ya implementadas. El resultado final de este análisis debe ser una lista priorizada de áreas de alto riesgo y una estrategia de control general para minimizar el riesgo para la organización en términos de impacto general. Los planes de gestión de riesgos de la cadena de suministro en materia de ciberseguridad incluyen disposiciones para las actividades que ocurren después de la conclusión de un acuerdo de colaboración o servicio.

Requisito GR.3	Tratamiento o un plan de acción correctivo sobre los riesgos encontrados y, de acuerdo a su resultado, implementar las acciones correctivas y preventivas correspondientes
Instituciones de salud	Se debe realizar una evaluación de los posibles riesgos y vulnerabilidades a la confidencialidad, integridad y disponibilidad de la Historia Clínica Electrónica (HCE). Además, se debe realizar una evaluación de riesgos con relación a la conectividad de dispositivos médicos, contemplando: identificación de activos, identificación de tipo de conectividad, casos de uso, flujos de comunicación, exposición de servicios a Internet, segregación/segmentación para ubicar estos activos, control de acceso a los dispositivos y a la red, acceso remoto, cifrado de comunicación en tránsito, uso de certificados, gestión, operación y monitoreo de los dispositivos, hardening, etc.
Instituciones Emisoras de Dinero Electrónico (IEDE)	No aplica
Guía de evidencia para auditoría	• Plan de tratamiento de riesgos incluyendo al menos, orden de prioridad y plazos de implementación de los controles identificados para tratar los riesgos. • Certificaciones funcionales y técnicas de las pruebas realizadas en los ambientes de test o calidad de que las vulnerabilidades han sido mitigadas. • Aprobaciones de los controles de cambio para las correcciones en los ambientes de producción. • Informe de reevaluación de mitigación o control de las vulnerabilidades. • Política de gestión de riesgos. • Inventario de riesgos de seguridad de la información. • Matriz de riesgos (impacto, probabilidad, tolerancia, controles). • Documentación de procesos críticos y su tolerancia al riesgo. • Actas o minutas de revisión de planes de tratamiento. • Reportes de indicadores de gestión de riesgos.
Normativa asociada	No aplica

← GR.2 Realizar de manera sistemática el proceso de evaluación de riesgos

GR.4 Inteligencia de amenazas →

[Ir al Índice](#)

Etiquetas

[Gestión y auditoría de Seguridad de la Información](#)

[Marco de Referencia](#)

[Política Digital del Uruguay](#)

[Políticas de Ciberseguridad](#)

[Ciberseguridad](#)

[Herramientas para la ciudadanía](#)

[Herramientas para organismos](#)

[Política Digital del Uruguay](#)

Índice

Introducción

Objetivo y Alcance

Requisitos

Organización y Gobernanza

Gestión de Riesgos

Gestión humana

Gestión de activos

Control de acceso

Seguridad física y del ambiente

Seguridad de las operaciones

Seguridad de las comunicaciones

Adquisición, desarrollo y mantenimiento de los sistemas

Relación con proveedores

Gestión de incidentes

Continuidad de las operaciones

Cumplimiento normativo y revisión

Protección de datos personales

Agencia de Gobierno Electrónico y Sociedad de la Información y del Conocimiento

Dirección: Liniers 1324 piso 4 (Montevideo, Uruguay)

Teléfono: (+598) 2901 2929

Contacto

Horario de atención: lunes a viernes de 9:00 a 17:00 h.

gub.uy